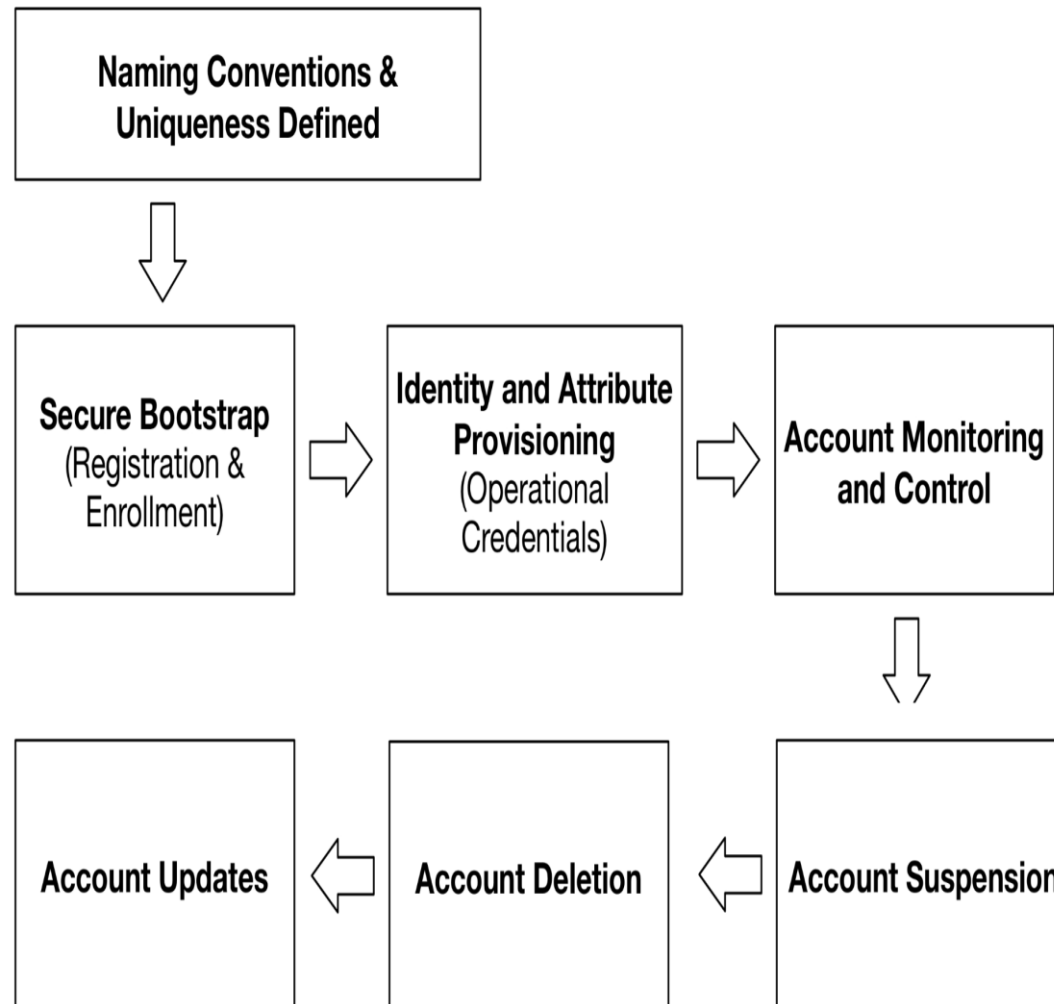
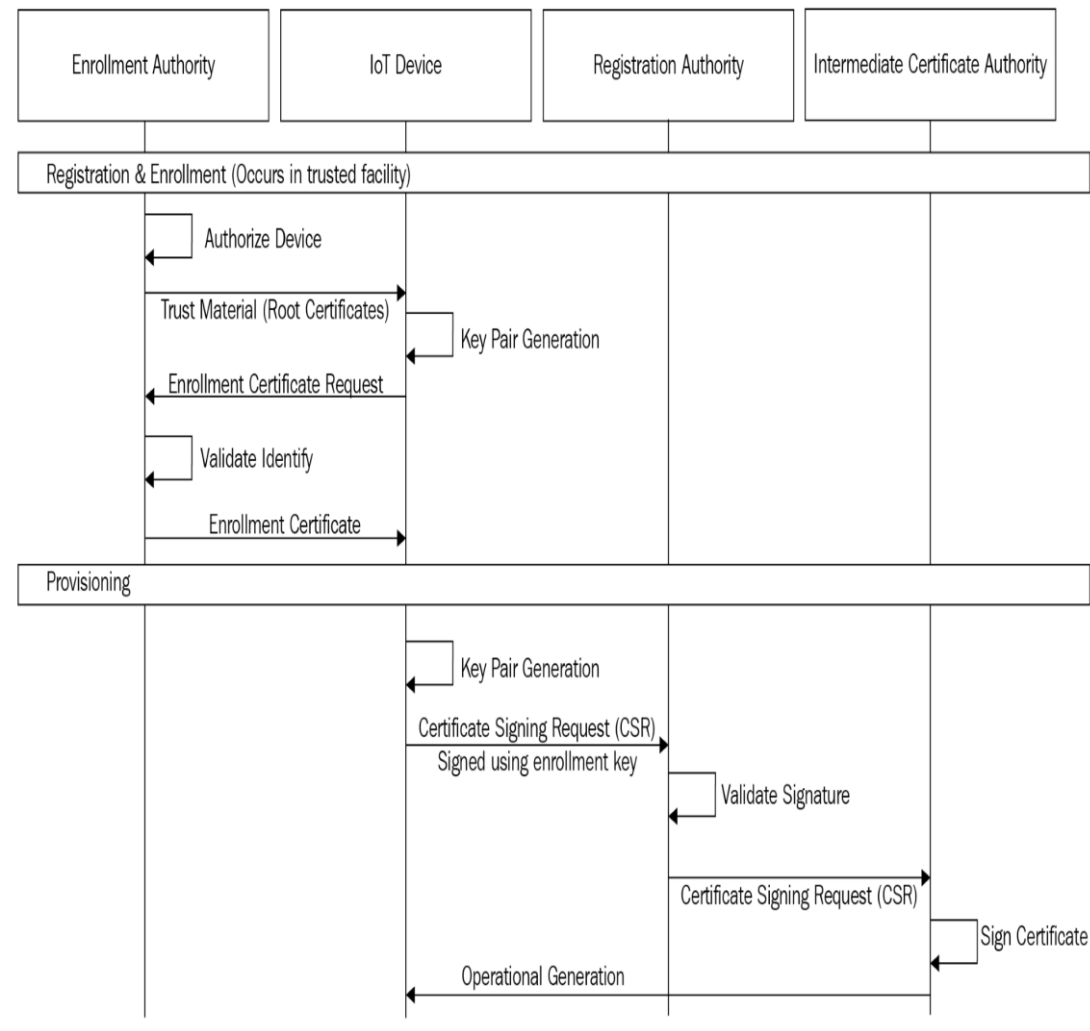




Russel & Van Duren: "Practical Internet of Things Security", 2nd edition, Packt Publishing, 2019

- Common attributes for naming a device
 - Manufacturer
 - Type
 - Serial number
 - Deployment date
 - Location
- Secure bootstrapping

Device Registration, Enrollment and Provisioning of Certificates

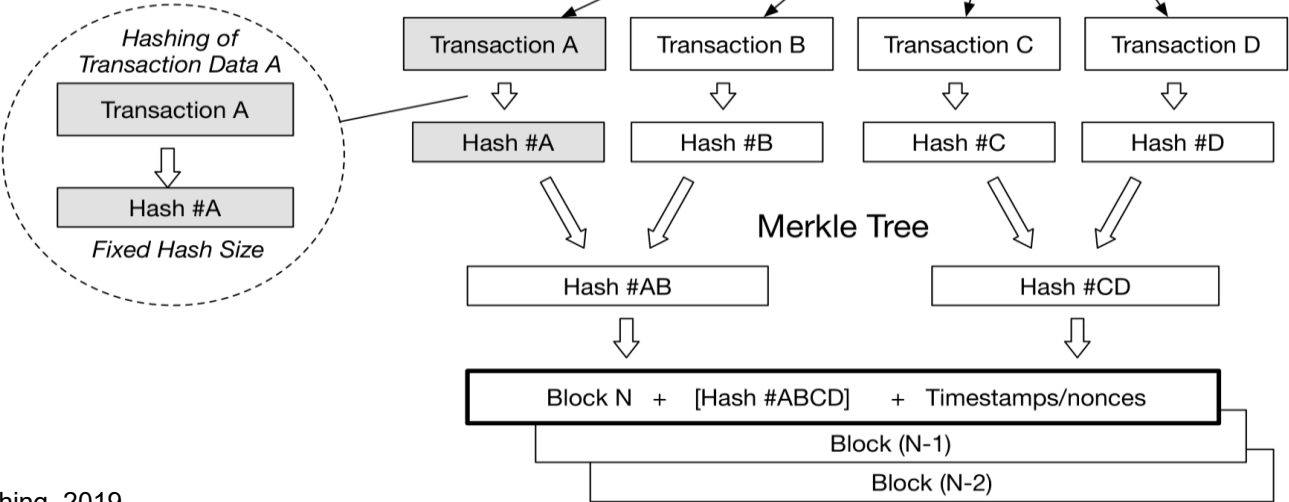
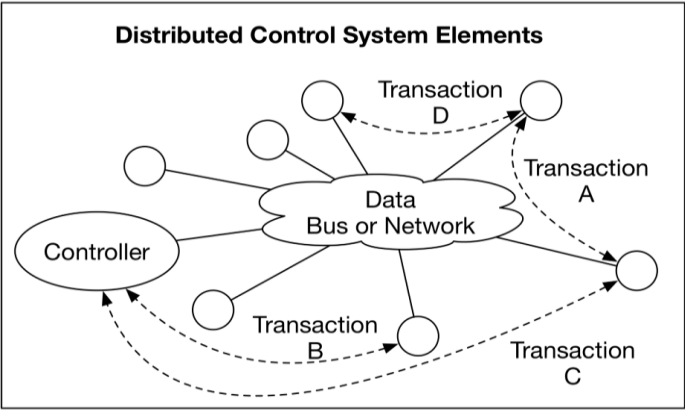
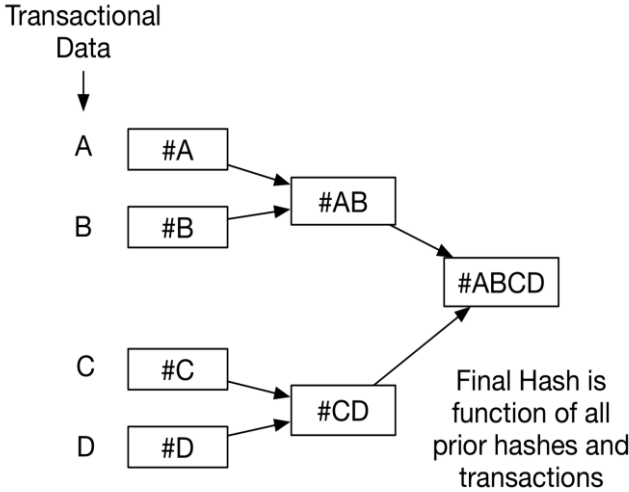


Credential and attribute provisioning

- Account monitoring and control
- Account updates
- Account suspension
- Account/credential deactivation/deletion

- Authentication credentials
 - Passwords
 - Symmetric keys
 - Certificates
 - Biometrics
 - Authorization for the IoT
- Certificates
 - X.509
 - IEEE 1609.2

- IoT Identity and Access Management (IAM) infrastructure
 - 802.1x
 - Public-Key Infrastructure (PKI) for the Internet of Things (IoT)
 - Trusted storage
 - PKI architecture for privacy
 - Revocation support
- Authorization and access control
 - OAuth 2.0 (token-based authorization framework specified in IETF RFC 6749)
 - Authorization and access controls within publish/subscribe protocols
 - Access controls within communication protocols
 - Decentralized trust via blockchain ledgers



- Complex sharing environment
 - Introduces new privacy concerns
 - Wearables
 - Smart homes
 - Cloud storage
 - Metadata can leak private information
- New privacy approaches for credentials
 - Pseudonymity
 - Anonymity
 - Short life span of certificates
 - Batches of certificates to allow a pool of credentials to be used for signing operations
 - Proxy gateway: Location Obscurer Proxy (LOP)
- Privacy Impact Assessment (PIA)

- New methods of surveillance
 - Drones
- Rules and laws from authorities
- Characterizing collected information
 - Not sensitive
 - Moderately sensitive
 - Very sensitive
- Uses of collected information
 - Viewing the data
 - Studies or analytics performed on the data for research purposes
 - Analysis of the data for marketing purposes
 - Reporting on the data to the end user
 - Selling or onward transfer of the data
 - Distillation and onward transfer of any processed metadata that originated from the user's raw data

- Need to identify where private information is being
 - Originated
 - Transmitted
 - Processed
 - Stored
- Need to notify the end user about the private information being collected
 - Printed product instruction sheet (provided within the packaging)
- Need to gain end user's consent (explicit vs. implicit)
 - User privacy agreement

- Data retention policies
 - What data are stored/collected and archived
 - When and how the data will be pushed or pulled from the device or mobile application
 - When and how data are destroyed
 - Any metadata or derived information that may be stored (aside from the IoT raw data)
 - How long the information will be stored (both during and after the life of the account to which it pertains)
 - If any controls/services are available to the end user to scrub any data they generate
 - Any special mechanisms for data handling in the event of legal issues or law-enforcement requests
- Information sharing
- Redress

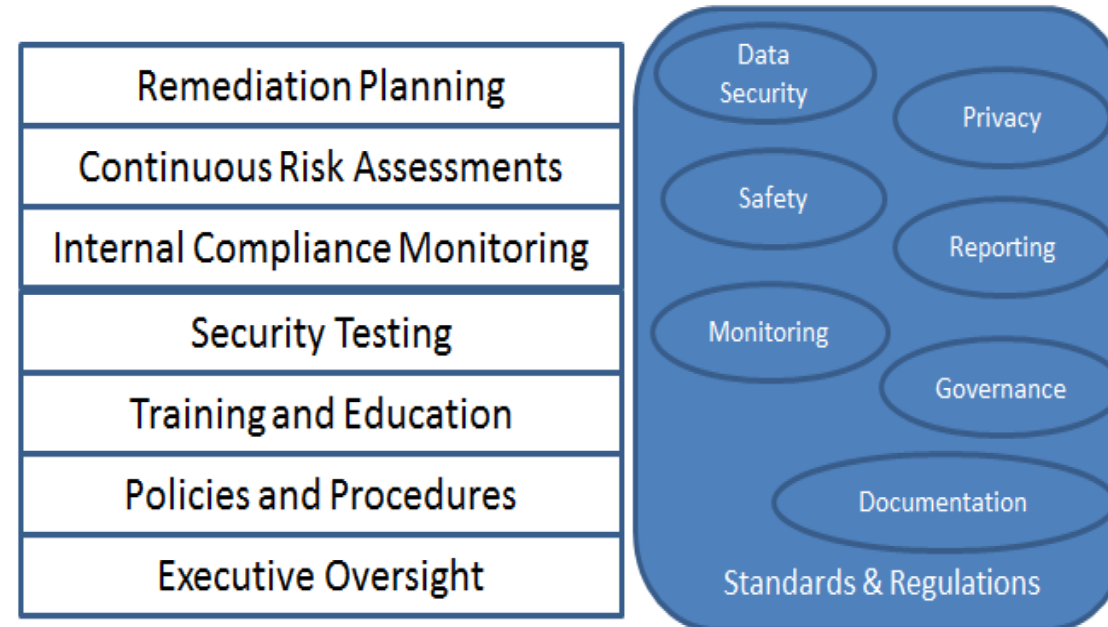
- Auditing and accountability
 - Insider and third-party auditing addresses which organizations and/or agencies provide oversight
 - Forensics
 - Technical detection of information (or information system) misuse (for example, a host auditing tool detects database access and a large query not emanating from the application server)
 - Security awareness, training processes, and supporting policies for those with direct or indirect access to the private information
 - Modifications to information-sharing processes, organizations with whom information is shared, and approval of any changes to policy
- Privacy by design

- Proactive not reactive; preventive and not remedial
- Privacy as the default
- Privacy embedded into design
- Full functionality – positive sum, not zero-sum
- End-to-end security – life cycle protection
- Visibility and transparency
- Respect for user privacy
- Privacy throughout the organization

- European General Data Protection Regulation (GDPR)
- European e-Privacy Regulation
- EU Article 29 Data Protection Working Party Opinion on the IoT

- US Privacy Act of 1974
- US Health Insurance Portability and Accountability Act (HIPAA)
- US Federal Trade Commission (FTC) Privacy Framework and Implementation Recommendations
- US FTC Report on Cross Device Tracking
- US Children's Online Privacy Protection Act (COPPA)

- Areas of interest
 - Security
 - Privacy
 - Trust
 - Resilience
 - Safety



IoT Compliance Program

Russel & Van Duren: "Practical Internet of Things Security", 2nd edition, Packt Publishing, 2019